

Tractable Problems in AI Security via Formal Methods

A sane way to burn a few postdoc-years

06.17.2026

Quinn Dougherty

Contents



1	The strategic landscape	3
1.a	<i>Let us treat ML training and inference with the seriousness of airplanes</i>	4
1.b	The White House	5
1.c	RAND	6
1.d	ARIA	7
1.e	Anthropic	8
1.f	Speed	9
2	The stack	10
2.a	5 layers	11
3	Tractable problems	12
3.a	Hardening protocol boundaries	13
3.b	Hardening OCI runtime	15
3.c	Device drivers for verified kernels	17
4	Onwards	19
4.a	How you can help	20

1 The strategic landscape

Let us treat ML training and inference with the seriousness of airplanes



Authors

Quinn Dougherty, Max von Hippel, Gregory Malecha, Nora Ammann

We mostly write about model weight confidentiality and integrity, but other notions of AI security are in scope. Not the biggest possible tent, but more than two invariants.



↶ PRESIDENTIAL ACTIONS

PROMOTING ADVANCED ARTIFICIAL INTELLIGENCE INNOVATION AND SECURITY

Executive Orders | June 2, 2026

Figure 1: Demands hardened critical infrastructure, doesn't say how.

Verified Machine Learning Infrastructure

Formal Methods for Trustworthy Artificial Intelligence Deployment

[Gopal P. Sarma](#), [Rachel Steratore](#), [Sunny D. Bhatt](#), [Geoffrey Irving](#)

RESEARCH — Published Jun 4, 2026



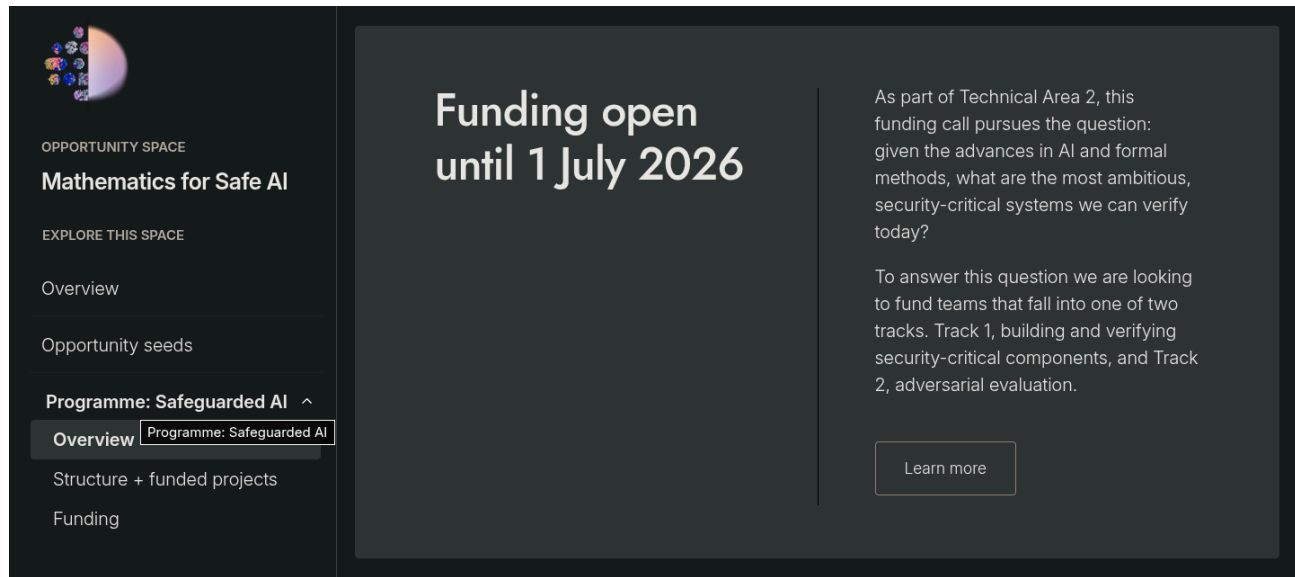
↓ **DOWNLOAD PDF**

ADDITIONAL DOWNLOADS

Includes Annex: Survey Instrument

📄 One-page overview

Figure 2: Expert survey, human and simulated/silicon



The image is a screenshot of the ARIA website. On the left is a dark sidebar with a logo at the top consisting of a semi-circle and a cluster of colorful dots. Below the logo, the text 'OPPORTUNITY SPACE' is followed by 'Mathematics for Safe AI'. Underneath is 'EXPLORE THIS SPACE' and a list of links: 'Overview', 'Opportunity seeds', 'Programme: Safeguarded AI' (with a dropdown arrow), 'Overview' (highlighted with a white border), 'Programme: Safeguarded AI' (in a small box), 'Structure + funded projects', and 'Funding'. The main content area has a dark background. It features the headline 'Funding open until 1 July 2026' in large white text. To the right, a paragraph explains that as part of Technical Area 2, the funding call pursues the question: 'given the advances in AI and formal methods, what are the most ambitious, security-critical systems we can verify today?'. Below this, another paragraph states: 'To answer this question we are looking to fund teams that fall into one of two tracks. Track 1, building and verifying security-critical components, and Track 2, adversarial evaluation.' At the bottom right of the main area is a 'Learn more' button.

OPPORTUNITY SPACE

Mathematics for Safe AI

EXPLORE THIS SPACE

Overview

Opportunity seeds

Programme: Safeguarded AI ^

Overview Programme: Safeguarded AI

Structure + funded projects

Funding

Funding open until 1 July 2026

As part of Technical Area 2, this funding call pursues the question: given the advances in AI and formal methods, what are the most ambitious, security-critical systems we can verify today?

To answer this question we are looking to fund teams that fall into one of two tracks. Track 1, building and verifying security-critical components, and Track 2, adversarial evaluation.

Learn more

Figure 3: Cyberhardening funding call at ARIA

Anthropic's Frontier Safety Roadmap

We believe that AI capabilities will improve rapidly in the coming years. We will need to quickly and dramatically improve our state of preparedness in a number of areas, especially:

Security

Preventing theft, sabotage and/or manipulation of our AI models.

Safeguards

Preventing dangerous use of our models via product surfaces and within Anthropic itself.

Figure 4: See *Leveling up across the board* at <https://www.anthropic.com/responsible-scaling-policy/roadmap>

Speed

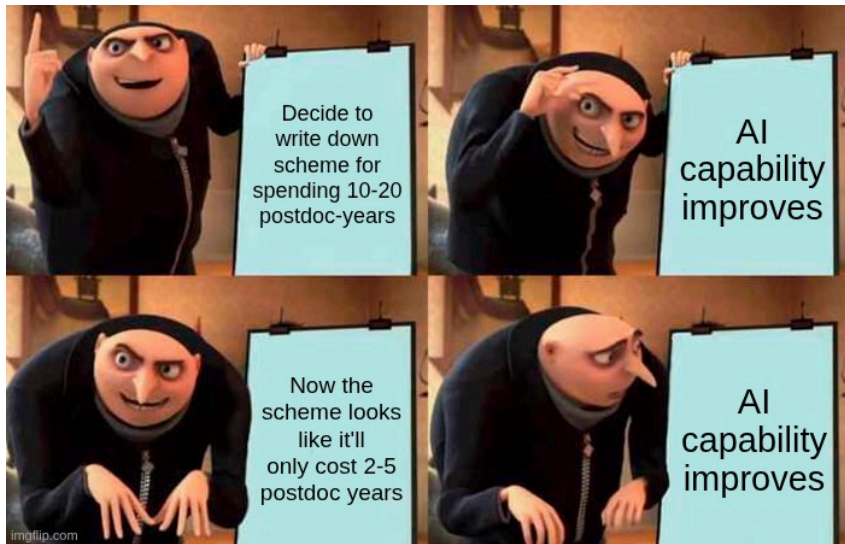


Figure 5: This is technically a violation of the meme format.

2 The stack

5 layers

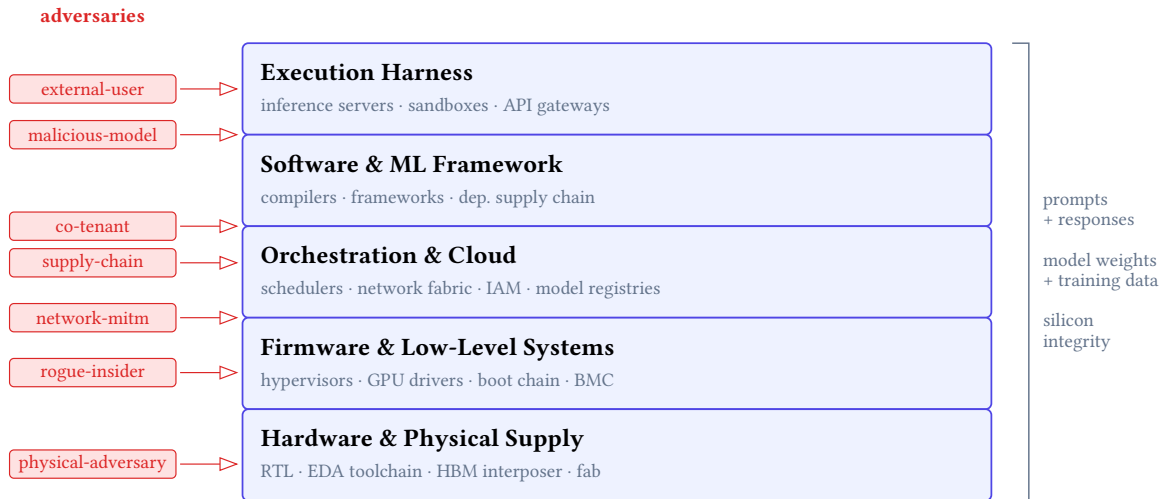


Figure 6: The path of a prompt from the enduser to the chip's circuits

3 Tractable problems

Hardening protocol boundaries



Chapter with Nora Ammann

Before any AI-specific machinery runs, a request has already crossed TLS, SSH, and WireGuard. The oldest trust boundaries, still the largest single-bug blast radius.

Status quo

Heartbleed, FREAK, Triple Handshake on TLS; regreSSHion (pre-auth remote root) on SSH — a signal-handler race, not even a parser bug. ARIA names verified TLS 1.3, SSH, and WireGuard as three of six example targets.

The shared shape

Every catastrophic bug is one of two things — memory unsafety in the parser, or an unintended transition in the state machine (downgrade, pre-auth confusion, stale-credential reuse). One LangSec pattern across all three protocols.

Hardening protocol boundaries (ii)



The good news

Each piece is already tractable in isolation — EverParse (verified parsers), Project Everest / miTLS (TLS in F*), Owl, Tamarin/ProVerif. Assume the crypto primitives (HACL*/EverCrypt); the kernel and side channels are out of scope.

The real blocker

No one ships a **single** proof spanning the whole boundary — parser, both state machines, and the daemon's concurrency/signal discipline — as a drop-in at a real edge. That gap, not a missing technique, is the widget.

The widget

Three instances sharing a parser-plus-state-machine method, so 2 and 3 are cheaper than 1: a drop-in TLS 1.3 server, a verified SSH boundary (covering the concurrency regressions exploited), and a verified WireGuard control plane (tunnel assumed verified; prove the membership state machine).

Hardening OCI runtime



Chapter with Max von Hippel

The container is the agent's cage. `runc` was never built to hold an adversary *inside* it.

Status quo

The standard runtime (`runc`) implements OCI atop Linux namespaces and cgroups — process isolation, never a security boundary. With an agent that writes and runs arbitrary code, that gap is the whole game.

The good news

We can now *measure* the gap. Frontier models are red-teamed for sandbox escape directly (UK AISI's toolkit + Docker breakout CTF, BashArena); BoxArena flips it to a **defensive** leaderboard — fix the attacker, vary the runtime (`runc`, `gVisor`, `crun`, `Kata`) across five surfaces.

Hardening OCI runtime (ii)



The real blocker

Empirical red-teaming is a treadmill — find a hole, patch it, a new escape surfaces next quarter. A capable enough agent should be assumed to find any flaw in its containment. That's the cue for proof, not more benchmarks.

The widget

A verified OCI runtime. Model the 80 syscalls a hardened container needs, specify the confinement policy (drop caps, read-only rootfs, seccomp allowlist, no-new-privs), prove no syscall sequence from inside breaks it. Pair the verified boundary with a scalable monitor — each makes the other's job easier.

Device drivers for verified kernels



Chapter with Gregory Malecha

The kernel can be verified; the driver underneath it usually can't.

Status quo

Multi-tenant GPU isolation rides on million-line hypervisor TCBs, with a proprietary ring-0 GPU driver as the single point of compromise.

The good news

seL4, NOVA, seKVM, and AWS Nitro verify a minimal core and push drivers out to deprived user-mode — the right architecture.

Device drivers for verified kernels (ii)



The real blocker

Not the proof, the spec. Driver proofs are a settled methodology (a verified ZynqMP DMA engine exists); what's missing is a machine-checkable model of the GPU's command / DMA / IOMMU surface. Vendors model the **ISA** — Arm, RISC-V, even AMD's shaders — not the device.

The widget

Specify one open GPU stack's command-submission ring (NVK/Nouveau) in Rocq/Lean; prove no guest command can drive a DMA or IOMMU mapping outside its region. Stub the hardware model first (reference), then co-develop a real one (research).

4 Onwards

How you can help



More contributions

Come aboard! More room for authors. Or, if you want to be low-key, comment on the website's native comments feature.

Tokens

Ask claude to implement one of the project sketches on `/problems`. Let us know how it goes.

Podcasts

What podcasts should we go on to discuss this? Get us invited.

I'm easy to find

`quinn@for-all.dev`